

Security Assessment Report

<https://github.com/minasielemma/cash-registroy/tree/main>

Hostname	github.com
Profile	STANDARD
Status	COMPLETED
Scan ID	140
Generated	2026-08-24 20:02 UTC

Overall Risk: CRITICAL | Total Findings: 1

This report was generated by Pistos Security for authorized security assessment purposes only.
Unauthorized scanning or testing of systems without explicit written permission is illegal.
The assessor assumes no liability for misuse of this tool or report.

RISK LEVEL	CRITICAL
TOTAL FINDINGS	1

Severity Distribution

CRITICAL	HIGH	MEDIUM	LOW	INFO
1	0	0	0	0

Findings Overview (1)

#	Severity	Title	Module	CVSS
1	CRITICAL	Security Misconfiguration	github_ai_scanner	9.8

Detailed Findings

CRITICAL		#1 Security Misconfiguration	
Module: github_ai_scanner CVSS: 9.8			
Description		File: settings.py, machines/models.py (lines 1-5) Missing parameterized queries in database interactions., Raw string formatting in database queries is prohibited.	
Remediation		Use parameterized queries or ORMs when interfacing with databases., Use parameterized queries or ORMs when interfacing with PostgreSQL, Redis Cache/Store, SQLite.	
Evidence		<pre>{ "line_end": 5, "file_path": "settings.py,machines/models.py", "confidence": 0.95, "line_start": 1, "validation_status": "CONFIRMED", "validation_reasoning": "The settings.py and machines/models.py files do not use parameterized queries, which makes them vulnerable to SQL injection attacks." }</pre>	

■ AI Security Analysis

Generated: 2026-08-24T19:43:12.407493+00:00

Executive Summary

The GitHub application has a critical security misconfiguration issue due to missing parameterized queries in database interactions and raw string formatting in database queries.

Risk Assessment

Critical

A critical security vulnerability exists due to the misuse of raw strings in database queries, allowing an attacker to inject malicious SQL code. This vulnerability can be exploited by an attacker to gain unauthorized access to sensitive data or execute system-level commands.

Critical Issues

- critical:** Missing parameterized queries in database interactions, Raw string formatting in database queries is prohibited.

Vulnerability Explanations

- Finding Title:** Security Misconfiguration, **ID/Module:** github_ai_scanner, **Exploitation Scenario:** An attacker can inject malicious SQL code by manipulating the raw string in the database query., **Technical Impact:** This vulnerability allows an attacker to gain unauthorized access to sensitive data or execute system-level commands., **Specific Risk:** High
- Finding Title:** Security Misconfiguration, **ID/Module:** github_ai_scanner, **Root Cause Analysis:** The application uses raw strings in database queries, which can be manipulated by an attacker to inject malicious SQL code., **Affected Components:** Database
- Database

Remediation Recommendations

[1. Remove the use of raw strings in database queries and instead use parameterized queries. 2. Review and refactor all database interactions to ensure they are secure and follow best practices.]

[1. Update the settings.py file to use parameterized queries for database interactions. 2. Review and update the machines/models.py file to remove raw strings in database queries. 3. Implement additional security measures such as input validation and sanitization.]

[1. Manually review and test the updated code to ensure it is secure and functional. 2. Automate testing using tools such as sqlmap or OWASP ZAP to identify any remaining vulnerabilities.]

- None

Recommended Fixes

[1. Remove the use of raw strings in database queries and instead use parameterized queries. 2. Review and refactor all database interactions to ensure they are secure and follow best practices.]

[1. Update the `settings.py` file to use parameterized queries for database interactions. 2. Review and update the `machines/models.py` file to remove raw strings in database queries. 3. Implement additional security measures such as input validation and sanitization.]

[1. Use parameterized queries instead of raw strings in database interactions. 2. Validate and sanitize all user inputs before passing them to the database.]

Secure Coding Best Practices

[1. Use parameterized queries instead of raw strings in database interactions. 2. Validate and sanitize all user inputs before passing them to the database.]

Infrastructure & Configuration

[1. Set the `SQLALCHEMY_DATABASE_URI` variable to use a secure connection string. 2. Enable the `XSS Protection` middleware to prevent cross-site scripting attacks.]

[1. Implement a Web Application Firewall (WAF) to detect and prevent common web attacks. 2. Monitor the application for suspicious activity and implement additional security measures as needed.]

[Implement additional security measures such as input validation and sanitization, and regularly review and update the application's security posture.]

Prioritized Action Plan

[P0] [1. Remove the use of raw strings in database queries and instead use parameterized queries. 2. Review and refactor all database interactions to ensure they are secure and follow best practices.]

Estimated Remediation Effort

[Time: 2 hours, Team: 1 person]

Security Standards References

- **Finding Title:** Security Misconfiguration, **OWASP Category:** A05:2021
- `{{'Finding Title': 'Security Misconfiguration', 'CWE ID': 'CWE-89'}}`

AI Remediation Prompt

Paste this prompt into your AI coding assistant (Cursor, Copilot, Claude, etc.):

- Fix Security Misconfiguration Vulnerability in GitHub Application
- Remove raw strings from database queries
- Parameterize database queries

